

Checklist

OSINT (Open-Source Intelligence) and Purple Teaming

1. Authorization and Scope

- ☐ Obtain written approval before conducting OSINT, penetration testing, or purple-team exercises.
- ☐ Define the systems, domains, networks, accounts, and locations that are in scope.
- ☐ Document rules of engagement and prohibited activities.
- ☐ Establish privacy, legal, and ethical requirements.
- ☐ Notify appropriate stakeholders and define escalation procedures.
- ☐ Use a controlled lab for techniques that could disrupt production systems.

2. Physical Asset Review

- ☐ Identify sensitive physical assets, including laptops, servers, documents, badges, and removable media.
- ☐ Review disposal procedures for confidential documents and equipment.
- ☐ Ensure sensitive paper records are shredded before disposal.
- ☐ Secure trash or recycling containing potentially sensitive material.
- ☐ Check workspaces for exposed passwords, account information, or confidential documents.
- ☐ Position monitors to reduce opportunities for shoulder surfing.
- ☐ Consider privacy screens where sensitive information is regularly viewed.
- ☐ Train staff to remain aware of their surroundings when handling sensitive data.

3. Email and Personnel Exposure

- ☐ Identify employee email addresses that are publicly discoverable.
- ☐ Review whether email naming conventions reveal unnecessary information.
- ☐ Assess exposure to phishing and social-engineering attacks.
- ☐ Consider monitored decoy/canary email accounts for defensive detection.
- ☐ Review public staff directories for excessive contact information.
- ☐ Check vendor and contractor information that could assist social engineering.
- ☐ Keep third-party and vendor contact information current.
- ☐ Provide phishing and social-engineering awareness training.

4. Technology and External Attack-Surface Review

- ☐ Inventory internet-facing domains and subdomains.
- ☐ Identify exposed IP addresses and services.
- ☐ Review DNS records and related infrastructure.
- ☐ Identify externally visible operating systems and software versions.
- ☐ Check for publicly exposed administrative interfaces.
- ☐ Review externally visible cloud services and hosting providers.
- ☐ Verify that unsupported or unnecessary services are removed.
- ☐ Track changes to the organization's external attack surface.

5. Metadata Review

- ☐ Inspect publicly available documents for metadata.
- ☐ Review images for EXIF information.
- ☐ Look for usernames, author names, software versions, and creation dates.
- ☐ Check for geographic information accidentally embedded in files.
- ☐ Remove unnecessary metadata before publishing documents.
- ☐ Incorporate metadata review into incident response and forensic procedures.

6. Public Web Content

- ☐ Search the organization's public website for sensitive information.
- ☐ Review publicly indexed files and directories.
- ☐ Check whether configuration or backup files have been accidentally exposed.
- ☐ Search for credentials, secrets, internal URLs, and sensitive keywords.
- ☐ Review cached or archived versions of public pages where appropriate.
- ☐ Establish a process for removing exposed information.
- ☐ Consider alerts for newly indexed sensitive content.

7. Personal and Social-Media Exposure

- ☐ Review what employees publicly disclose about their roles and responsibilities.
- ☐ Look for posts revealing new software, vendors, technologies, or projects.
- ☐ Check for photographs exposing badges, screens, office layouts, or equipment.
- ☐ Review whether posts reveal travel, schedules, or organizational changes.
- ☐ Train staff to limit unnecessary disclosure of workplace information.
- ☐ Extend security awareness guidance to remote and home-working situations.

8. Data-Breach Exposure

- ☐ Determine whether organizational email addresses appear in known breaches.
- ☐ Identify accounts at increased risk of credential-stuffing attacks.
- ☐ Enforce unique passwords across services.
- ☐ Require multifactor authentication where possible.
- ☐ Reset or disable compromised credentials promptly.
- ☐ Monitor for reused or exposed credentials.

9. OSINT Framework

- ☐ Use an OSINT framework to organize investigation categories.
- ☐ Select tools according to the type of information being investigated.
- ☐ Record the source and reliability of each finding.
- ☐ Separate confirmed facts from assumptions.
- ☐ Avoid collecting more personal information than necessary.
- ☐ Document findings so that another analyst can reproduce the investigation.
- ☐ Remember that tools support analysis but do not replace analyst judgment.

10. Maltego Review

- ☐ Start with an authorized domain or other approved entity.
- ☐ Use transforms to identify related infrastructure and information.
- ☐ Review DNS, email, website, and other relevant relationships.
- ☐ Avoid running excessive transforms without a clear objective.
- ☐ Switch between graph and list views to analyze large result sets.
- ☐ Validate important findings using independent sources.
- ☐ Export or document useful results for remediation.

- ☐ Protect any sensitive information collected during the investigation.

11. Shodan / Internet-Exposure Review

- ☐ Search only for systems within the approved scope.
- ☐ Identify publicly visible devices and services.
- ☐ Review exposed ports and service banners.
- ☐ Compare detected products and versions with known vulnerabilities.
- ☐ Look for patterns that reveal a specific technology or vendor.
- ☐ Use filters or facets to narrow large result sets.
- ☐ Export a prioritized list of assets requiring investigation.
- ☐ Correct unnecessary internet exposure.
- ☐ Consider continuous monitoring for changes to the digital footprint.

12. Purple-Team Planning

- ☐ Define the security control or scenario being tested.
- ☐ Establish clear red-team and blue-team responsibilities.
- ☐ Agree on objectives and measurable success criteria.
- ☐ Confirm that testing occurs only within authorized scope.
- ☐ Create communication and emergency-stop procedures.
- ☐ Record the expected defensive detections before testing begins.
- ☐ Ensure backups and recovery procedures are available where needed.

13. Red-Team Exercise

- ☐ Simulate realistic attacker behavior rather than pursuing unnecessary exploitation.
- ☐ Test whether exposed information can meaningfully support an attack path.
- ☐ Record each technique attempted.
- ☐ Record which techniques succeed or fail.
- ☐ Minimize disruption to production services.
- ☐ Preserve evidence needed for later analysis.
- ☐ Stop testing immediately if safety or scope limits are exceeded.

14. Blue-Team Exercise

- ☐ Verify that expected alerts are generated.
- ☐ Confirm that logs contain enough information to investigate the activity.
- ☐ Measure how quickly suspicious activity is identified.
- ☐ Test escalation and incident-response procedures.
- ☐ Check whether analysts can determine the affected hosts and accounts.
- ☐ Confirm that containment actions work as intended.
- ☐ Identify gaps in telemetry, logging, and detection coverage.

15. Responder / Coerced-Authentication Lab Exercise

- ☐ Perform the exercise only on systems you own or are explicitly authorized to test.
- ☐ Use an isolated lab whenever possible.
- ☐ Confirm that participating Windows systems and test accounts are designated for the exercise.
- ☐ Identify the network behavior being tested, such as LLMNR/NBT-NS/WPAD exposure.
- ☐ Monitor whether authentication attempts can be induced under test conditions.
- ☐ Verify whether the blue team detects the activity.
- ☐ Do not reuse or access captured authentication material outside the authorized exercise.
- ☐ Disable unnecessary LLMNR, NBT-NS, or WPAD functionality where appropriate.
- ☐ Strengthen SMB and authentication protections.
- ☐ Review relevant endpoint, network, and identity logs after testing.

16. Post-Exercise Review

- ☐ Compare red-team activity with blue-team detections.
- ☐ Identify vulnerabilities, visibility gaps, and process failures.
- ☐ Rank findings by risk and business impact.
- ☐ Assign remediation owners.
- ☐ Establish remediation deadlines.
- ☐ Update detection rules and monitoring.
- ☐ Improve security awareness training where human factors contributed.
- ☐ Update documentation and incident-response procedures.
- ☐ Retest corrected weaknesses.
- ☐ Record lessons learned for the next purple-team exercise.

17. Continuous Improvement

- ☐ Monitor the organization's public digital footprint regularly.
- ☐ Reassess OSINT exposure after major organizational or technology changes.
- ☐ Repeat purple-team exercises periodically.
- ☐ Track whether previously identified weaknesses return.
- ☐ Incorporate new attacker techniques into future exercises.
- ☐ Treat every discovered weakness as an opportunity to strengthen defenses.